

UK GDPR Security Control Assessment

Technical report | Report date 1 September 2026

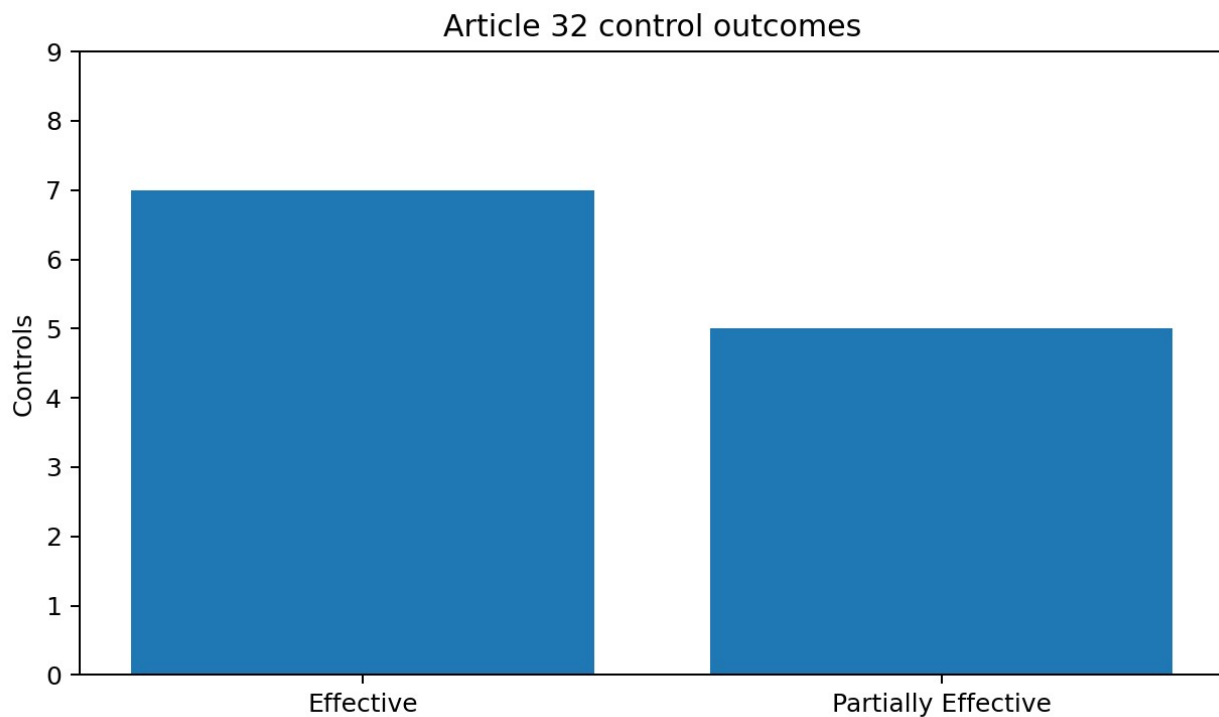
Meridian Trust Bank plc (MT-ENT-002) - fictional portfolio case study

Portfolio Case Study - fictional/synthetic MTFS content only. Methodology demonstration; not a real client audit, certification audit, legal opinion or regulatory assurance engagement.

Assessment verdict

Needs improvement. Seven of twelve selected control outcomes were Effective and five were Partially Effective. The five partial outcomes are supported by material exceptions and are reported as findings. The assessment does not conclude on legal compliance with the UK GDPR as a whole.

12 Article 32 outcomes	7 Effective	5 Partial	5 Findings
----------------------------------	-----------------------	---------------------	----------------------



1. Scope, boundary and criteria

Engagement type: security and technical/organisational control assurance supporting UK GDPR compliance. It is not legal advice, an ICO audit, regulatory assurance or certification.

Primary entity: MT-ENT-002 Meridian Trust Bank plc. Assessment period 1 April-31 July 2026; fieldwork 3-21 August 2026.

In-scope assurance areas

- Article 32 risk-appropriate technical/organisational security measures
- ROPA/processing context sufficient to anchor the security assessment
- Article 33-style personal-data breach readiness
- Articles 15/17 rights-process workflow review
- Articles 28/32 processor-security assurance
- Chapter V restricted-transfer spot checks using UK safeguards

Explicit exclusions

Full Article-by-Article legal compliance; lawful basis; privacy notices; PECR; full DPIA legal sufficiency; automated-decision legality; full retention-law analysis; penetration testing; DORA/EEA assessment; financial-audit ITGC or SAP control testing.

Public criteria used

UK GDPR Articles 5(1)(f), 5(2), 15, 17, 28, 32, 33 and Chapter V/Article 46 concepts, interpreted for this portfolio through current ICO guidance and the Data (Use and Access) Act 2025 changes where material.

2. Processing and data context

Article 32 appropriateness depends on risk and processing context. Six selected processing activities anchor the assessment in customer identity, account/transaction, authentication, fraud, privacy-case and workforce-access data.

Processing	Activity	Data subjects	Applications	Processors
GDPR-PA-001	Current account and savings servicing	Retail and SME customers	MT-APP-011;MT-APP-012;MT-APP-018	MT-TP-001;MT-TP-010
GDPR-PA-002	Digital authentication and account access	Customers and workforce administrators	MT-APP-001;MT-APP-012	MT-TP-001
GDPR-PA-003	Fraud response and account protection	Customers	MT-APP-018;MT-APP-014	MT-TP-008;MT-TP-010
GDPR-PA-004	Customer onboarding and identity verification	Prospective customers	MT-APP-012;MT-APP-018	MT-TP-010;MT-TP-011
GDPR-PA-005	Privacy rights and personal-data incident coordination	Customers; employees; requesters	MT-APP-019;MT-APP-018;MT-APP-002	MT-TP-003;MT-TP-010;MT-TP-001
GDPR-PA-006	Workforce identity and access administration	Employees and contractors	MT-APP-001;MT-APP-007	MT-TP-001;MT-TP-003

Key canonical risk linkages

- MT-RSK-001 Identity & Access
- MT-RSK-003 Vulnerability Management
- MT-RSK-004 Security Monitoring & Logging
- MT-RSK-005 Backup & Recovery
- MT-RSK-006 Third-Party ICT
- MT-RSK-007 Data Protection & Confidentiality
- MT-RSK-009 Cyber Incident Response

The ROPA file in this repository is a sample extract used as an assurance input. It is not presented as a legal sufficiency determination under Article 30.

3. Assessment methodology

The methodology preserves the portfolio chain: risk -> control objective -> control -> design effectiveness -> population/sample -> evidence -> exception -> underlying issue -> GDPR finding -> remediation -> future retest.

Design vs operating effectiveness

Design effectiveness considers whether the defined control could meet the intended security outcome. Operating effectiveness considers whether it operated consistently during the period. Inquiry alone was not accepted as sufficient operating-effectiveness evidence where the control should leave a record.

Sampling rationale

Sampling is risk-directed rather than statistical. Full-population testing was used for small/high-impact populations such as 42 privileged identities, 12 critical log sources and 27 Critical/High vulnerabilities. Judgemental samples were used where full-population testing added little assurance: 20 of 99 JML events, 4 of 8 critical backup sets, 3 of 5 material processors, 12 of 74 rights cases and 2 selected restricted-transfer paths.

Evidence sufficiency

Evidence was evaluated for relevance, reliability, completeness, timeliness, integrity and corroboration. Twenty-two synthetic evidence artifacts are logged and hashed with SHA-256. The manifest is generated from the actual files and is validated before release.

Finding rating

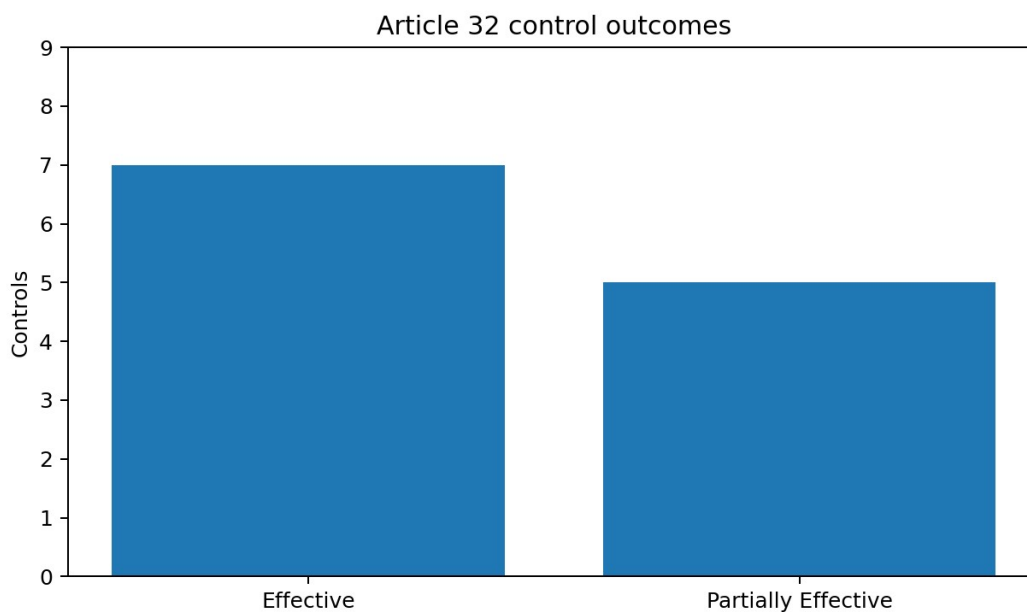
Likelihood and impact are each scored 1-5; score is the product. Thresholds: 1-4 Low, 5-9 Moderate, 10-16 High, 17-25 Critical. Planned management action does not change the historical assessment rating.

4. Article 32 control results

Control	Theme	Design	Operating	Sample	Finding
GDPR-CTL-001	Security governance & risk management	Effective	Effective	2 of 2	-
GDPR-CTL-002	Privileged authentication	Partially Effective	Partially Effective	42 of 42	GDPR-FND-001
GDPR-CTL-003	Joiner/mover/leaver access	Effective	Effective	20 records (12 leavers, 8 movers)	-
GDPR-CTL-004	Encryption & key protection	Effective	Effective	6 of 6	-
GDPR-CTL-005	Data loss prevention / exfiltration protection	Effective	Effective	8 incidents plus all 12 policy-rule configurations	-
GDPR-CTL-006	Vulnerability management	Effective	Partially Effective	27 of 27	GDPR-FND-005
GDPR-CTL-007	Logging & security monitoring	Effective	Partially Effective	12 of 12	GDPR-FND-002
GDPR-CTL-008	Availability & resilience	Effective	Effective	4 of 4	-
GDPR-CTL-009	Backup restore capability	Effective	Partially Effective	4 backup sets including core banking, CRM, privacy case management and identity configuration	GDPR-FND-003
GDPR-CTL-010	Control effectiveness testing	Effective	Effective	6 of 6	-
GDPR-CTL-011	Personal-data breach readiness	Effective	Effective	1 tabletop + 5 incident records	-
GDPR-CTL-012	Processor security assurance	Effective	Partially Effective	3 processors: MT-TP-001, MT-TP-003, MT-TP-010	GDPR-FND-004

Result interpretation

Seven controls were Effective. Five controls were Partially Effective and produced the five findings below. No selected control was rated wholly Ineffective. This coverage is intentionally deep rather than an exhaustive checklist of every possible technical measure.



5. Detailed findings - identity and monitoring

GDPR-FND-001 - Legacy privileged access path does not consistently enforce MFA (High)

Element	Detail
Underlying issue / risk	MT-IAM-001 MT-RSK-001;MT-RSK-007
Condition	Three of 42 privileged identities remained able to use a legacy remote-access path without the approved MFA enforcement.
Criteria / expected state	Authentication safeguards for privileged access should be proportionate to the high impact of administrative compromise and consistently applied across access paths.
Cause	Legacy VPN migration created an exception path that was not brought under equivalent conditional-access enforcement; compensating controls were not formally defined for all affected identities.
Risk	Compromise of a privileged credential could enable unauthorised access to systems processing customer personal information, increasing confidentiality, integrity and account-security risk.
Evidence / testing	MT-EV-503;MT-EV-504 MT-TST-502;MT-WP-502;MT-EXC-501
Recommendation	Retire or isolate the legacy path; enforce phishing-resistant or otherwise risk-appropriate MFA for privileged interactive access; define tightly controlled emergency-account exceptions; and monitor/report any remaining bypasses until closure.
Management action	Agreed. IAM will migrate vendor support to the modern access path and place break-glass accounts under enhanced monitoring with documented activation controls. Owner: Director of IAM; target 2026-10-31.

GDPR-FND-002 - Central monitoring does not cover two critical personal-data systems (High)

Element	Detail
Underlying issue / risk	MT-LOG-001 MT-RSK-004;MT-RSK-007;MT-RSK-009
Condition	Two of 12 critical sources - Meridian Customer CRM audit logs and Privacy Case Management administrative activity - were retained locally but not centrally ingested or covered by Sentinel alerting.
Criteria / expected state	Security-relevant activity affecting restricted personal information should be available for timely detection, investigation and correlation at a level proportionate to risk.
Cause	SIEM onboarding prioritised core transaction and identity systems; privacy/CRM administrative logs were left in a backlog without risk-based completion dates.
Risk	Misuse or compromise of privileged access in the two systems may be detected late or require fragmented investigation, increasing the chance and duration of unauthorised processing.
Evidence / testing	MT-EV-509;MT-EV-510 MT-TST-507;MT-WP-507;MT-EXC-502
Recommendation	Risk-rank and onboard both sources to central monitoring, implement priority privileged/admin activity detections, confirm retention and time synchronisation, and add quarterly reconciliation of critical systems to SIEM coverage.
Management action	Agreed. SOC engineering has created onboarding work items for CRM and privacy-case administration logs. Owner: Head of Security Operations; target 2026-11-15.

6. Detailed findings - recovery and processor assurance

GDPR-FND-003 - Critical core-banking restore testing evidence is incomplete (High)

Element	Detail
Underlying issue / risk	MT-RES-001 MT-RSK-005;MT-RSK-007;MT-RSK-010
Condition	Backups were operating, but one of four sampled critical backup sets - the core-banking platform - had no completed annual restore-test evidence in the prior 12 months.
Criteria / expected state	Recovery capability for critical personal-data processing should be periodically tested so the organisation can demonstrate timely restoration, not only backup-job success.
Cause	The planned restore exercise was rescheduled twice because of release-calendar conflicts; governance did not escalate repeated deferral against the criticality of the service.
Risk	A latent restore defect could remain undetected until a real disruption, extending loss of availability or access to customer information.
Evidence / testing	MT-EV-512;MT-EV-513 MT-TST-509;MT-WP-509;MT-EXC-503
Recommendation	Complete an end-to-end core-banking restore exercise against approved recovery objectives, record data-integrity validation, and require formal risk acceptance/escalation when critical restore tests are deferred.
Management action	Agreed. Recovery Engineering has reserved a controlled exercise window and will obtain business-owner sign-off on recovered data validation. Owner: Director of Cloud & Infrastructure; target 2026-10-15.

GDPR-FND-004 - Ongoing security assurance for a material CRM processor is overdue (Moderate)

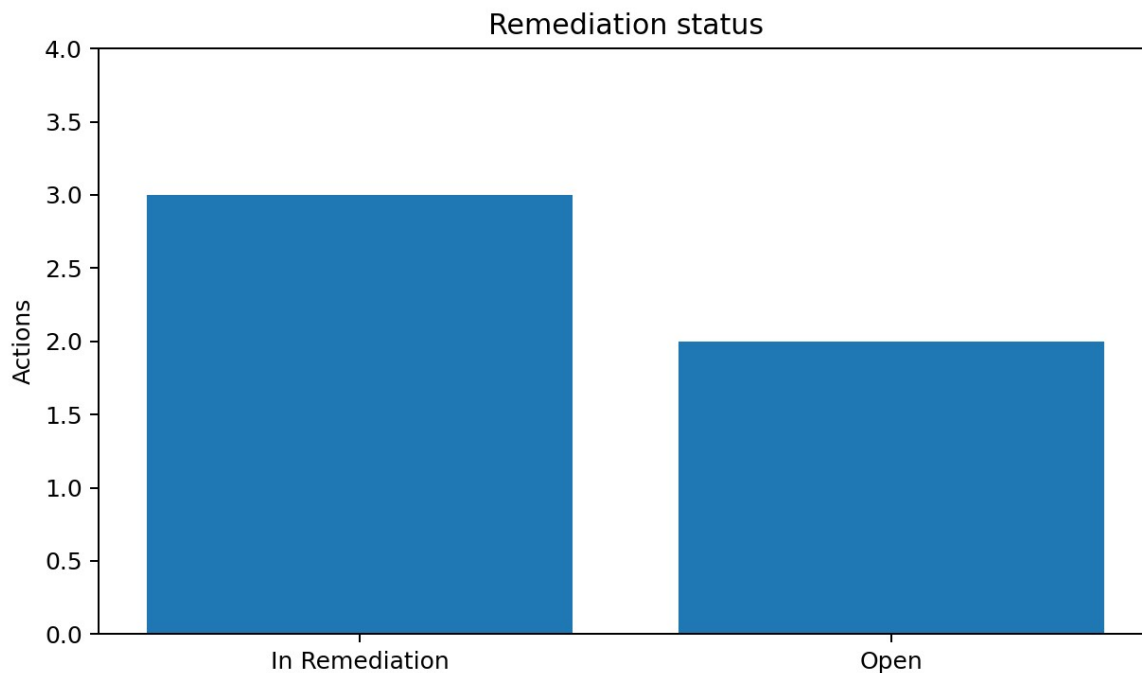
Element	Detail
Underlying issue / risk	MT-TPR-001 MT-RSK-006;MT-RSK-007
Condition	Northbridge CRM Services Ltd had not received its planned annual security assurance refresh since January 2025, and a penetration-test remediation item in the prior review had no documented closure evidence.
Criteria / expected state	A controller should maintain risk-proportionate assurance that a processor provides sufficient guarantees and continues to operate appropriate security measures, with identified weaknesses tracked to closure.
Cause	Third-party risk scheduling focused on DORA/critical-service providers and did not preserve privacy-processor review cadence for this UK CRM relationship.
Risk	MTFS may lack current assurance over security controls protecting customer information processed by a material supplier, weakening accountability and increasing exposure to undetected supplier control deterioration.
Evidence / testing	MT-EV-517;MT-EV-518 MT-TST-512;MT-WP-512;MT-EXC-504
Recommendation	Complete a refreshed risk-based security assessment of Northbridge, obtain closure evidence for the prior penetration-test action, record subprocessor/transfer changes, and integrate privacy-processor review dates into the enterprise third-party assurance schedule.
Management action	Agreed. Supplier Risk and Privacy will run a joint assurance refresh and move the relationship to a single risk-based review calendar. Owner: Head of Third-Party Risk; target 2026-12-15.

7. Detailed finding - vulnerability ageing

Element	Detail
Finding	GDPR-FND-005 - Critical and high vulnerabilities exceed approved remediation windows (High, score 12)
Underlying issue / risk	MT-VUL-001 MT-RSK-003;MT-RSK-007
Condition	Ten of 27 Critical/High vulnerabilities on selected personal-data systems exceeded approved remediation windows at 31 July 2026, including four Critical items.
Criteria / expected state	Known vulnerabilities affecting personal-data processing should be assessed and remediated within risk-based timelines, with time-bound exceptions where treatment is delayed.
Cause	Application release dependencies and incomplete ownership escalation allowed vulnerability tickets to age beyond SLA without consistent compensating-control or exception records.
Risk	Known exploitable weaknesses may remain available to attackers for longer than risk appetite, increasing the probability of compromise, data exposure or service disruption.
Evidence / testing	MT-EV-508 MT-TST-506;MT-WP-506;MT-EXC-505
Recommendation	Prioritise the four Critical items, enforce owner escalation before SLA breach, require documented time-bound exceptions with compensating controls, and introduce weekly aged-vulnerability reporting for restricted-data assets.
Management action	Agreed. Vulnerability Management will establish an executive escalation queue for Critical items and require formal exceptions for overdue High items. Owner: Head of Vulnerability Management; target 2026-10-31.

Remediation status

Action	Finding	Status	Owner	Target
MT-REM-501	GDPR-FND-001	In Remediation	Director of IAM	2026-10-31
MT-REM-502	GDPR-FND-002	In Remediation	Head of Security Operations	2026-11-15
MT-REM-503	GDPR-FND-003	In Remediation	Director of Cloud & Infrastructure	2026-10-15
MT-REM-504	GDPR-FND-004	Open	Head of Third-Party Risk	2026-12-15
MT-REM-505	GDPR-FND-005	Open	Head of Vulnerability Management	2026-10-31



8. Supporting governance exercises

Breach readiness - Article 33-style tabletop

Synthetic scenario: unauthorised access to 860 customer accounts with contact-data exfiltration for 143. The DPO was engaged 37 minutes after awareness; a notification decision was made the same day; the hypothetical submission package was ready after 26 hours 30 minutes. No real ICO notification occurred.

Data subject rights - Articles 15 and 17 process review

Population 74 Q2 cases; 12 sampled. All were timely under the documented workflow. The review explicitly considered DUAA 2025 clarification timing and the requirement to make reasonable and proportionate searches. Two terse search-rationale records were treated as an advisory documentation observation, not a material finding.

Processor security - Articles 28 and 32

Three of five material processors were sampled. Contractual design was adequate in all three. Northbridge operating assurance was stale, producing GDPR-FND-004.

Restricted transfers - Chapter V

Two US support paths were spot-checked. One used the UK Addendum and one used the UK IDTA. Both had a documented TRA/data protection test and additional security measures. The assessment does not treat EU SCCs alone as the UK transfer mechanism.

9. Evidence lineage and cross-framework traceability

Evidence lineage

The evidence log contains 22 synthetic artifacts. Each record includes an MT-EV ID, exact relative path, SHA-256 hash, source owner/system, collection timestamp, period, canonical asset/application/service linkage and control/test references. Evidence files are immutable after logging; changed evidence receives a new ID.

Canonical issue reuse

GDPR finding	Underlying issue	Condition theme
GDPR-FND-001	MT-IAM-001	Legacy privileged access path does not consistently enforce MFA
GDPR-FND-002	MT-LOG-001	Central monitoring does not cover two critical personal-data systems
GDPR-FND-003	MT-RES-001	Critical core-banking restore testing evidence is incomplete
GDPR-FND-004	MT-TPR-001	Ongoing security assurance for a material CRM processor is overdue
GDPR-FND-005	MT-VUL-001	Critical and high vulnerabilities exceed approved remediation windows

This reuse is deliberate: the same underlying condition is not assigned a new technical issue solely because UK GDPR provides a different assurance lens. Framework-specific criteria and findings remain separate.

Open finding closure rule

All five findings remain Open or In Remediation. No closure or retest has been fabricated. Closure requires new evidence and a targeted retest linked to the original exception and remediation action.

10. Conclusion and source register

Conclusion

The selected control environment provides meaningful protection for personal information but requires remediation in five areas before stronger assurance is warranted. The highest priorities are privileged-access MFA consistency, vulnerability ageing, central monitoring coverage and evidenced core-banking recovery. Processor assurance should be refreshed on a risk-based schedule. Supporting breach, rights and transfer exercises were satisfactory within their stated scope.

Authoritative public sources checked 1 September 2026

- ICO - Security outcomes (UK GDPR security guidance).
- ICO - Personal data breach reporting processes / 72-hour readiness.
- ICO - A guide to subject access, updated 16 July 2026.
- ICO - Right to erasure.
- ICO - Records of processing and lawful basis audit framework.
- ICO - Controller/processor responsibilities and Article 28 contract guidance.
- ICO - International transfers, appropriate safeguards and transfer risk assessment guidance updated in 2026.
- ICO - Data (Use and Access) Act 2025 implications for organisations, updated 19 June 2026.
- GOV.UK - Data (Use and Access) Act 2025 data-protection/privacy changes.

Full URLs are maintained in references/framework-sources.md and the assessment workbook. The portfolio uses public UK GDPR Article identifiers and original assessment wording; it does not reproduce proprietary standards.

Final boundary statement

This report demonstrates GRC/cyber-assurance methodology using fictional/synthetic information. It does not represent professional client work and does not provide a legal opinion or regulatory assurance conclusion.